Overview
Core Concepts
Architecture
Implementation
Code Examples
Best Practices
Common Pitfalls
Interview Questions
Quick Reference

API Gateway Pattern

Overview

What is an API Gateway?

An API Gateway is a server that acts as a single entry point for a set of microservices. It sits between client applications and backend services, routing requests, composing responses, and handling cross-cutting concerns like authentication, rate limiting, and logging.

Why Use an API Gateway?

- **Simplifies client code** — clients talk to one endpoint instead of many
- **Centralizes cross-cutting concerns** — auth, logging, rate limiting in one place
- **Reduces round trips** — aggregate multiple service calls into one
- **Protocol translation** — expose REST externally while services use gRPC internally
- **Decouples clients from services** — services can change without affecting clients

When NOT to Use an API Gateway

- Small monolithic applications with a single backend
- Internal service-to-service communication (use a service mesh instead)
- When the gateway becomes a bottleneck and you haven't scaled it properly

Core Concepts

Request Routing

The gateway maps incoming URL paths to backend services. Routing can be based on path, headers, query parameters, or HTTP method.

Authentication & Authorization

The gateway validates tokens (JWT, OAuth2) before forwarding requests. Backend services trust the gateway and don't need to re-authenticate.

Rate Limiting

Protects backend services from overload by limiting the number of requests per client, per time window.

Request Aggregation

Combines responses from multiple services into a single response, reducing the number of round trips for clients.

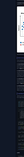
Circuit Breaker

Prevents cascading failures by stopping requests to a failing service and returning a fallback response.

Caching

Stores responses for frequently requested data to reduce load on backend services.

Architecture



Single Gateway

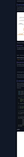
One gateway handles all traffic. Simple but can become a bottleneck.

Backend for Frontend (BFF)

Separate gateways for different client types (web, mobile, IoT), each tailored to its client's needs.

Gateway Clusters

Multiple gateway instances behind a load balancer for high availability and scalability.



Implementation

Popular Gateway Solutions

Solution	Type	Best For
Kong	Open source / Enterprise	Plugin ecosystem, Lua extensibility
AWS API Gateway	Managed	Serverless, AWS integration
Nginx	Open source	High performance, reverse proxy
Envoy	Open source	Service mesh, gRPC
Spring Cloud Gateway	Open source	Spring Boot ecosystem
Traefik	Open source	Docker, Kubernetes auto-discovery

Request Flow

1. Client sends request to gateway
2. Gateway authenticates the request
3. Gateway checks rate limits
4. Gateway routes to the appropriate backend service
5. Backend service processes the request
6. Gateway transforms the response if needed
7. Gateway returns response to client

Code Examples

Simple Gateway with Express

```
const express = require('express');
const { createProxyMiddleware } = require('http-proxy-middleware');

const app = express();

app.use('/users', createProxyMiddleware({ target: 'http://user-service:3001' }));
app.use('/orders', createProxyMiddleware({ target: 'http://order-service:3002' }));
app.use('/products', createProxyMiddleware({ target: 'http://product-service:3003' }));

app.listen(3000, () => console.log('Gateway running on port 3000'));
```

Rate Limiting Middleware

```
const rateLimit = new Map();

function rateLimiter(maxRequests, windowMs) {
  return (req, res, next) => {
    const key = req.ip;
    const now = Date.now();
    const record = rateLimit.get(key) || { count: 0, start: now };

    if (now - record.start > windowMs) {
      record.count = 0;
      record.start = now;
    }

    record.count++;
    rateLimit.set(key, record);

    if (record.count > maxRequests) {
      return res.status(429).json({ error: 'Too many requests' });
    }

    next();
  };
}

app.use(rateLimiter(100, 60000)); // 100 requests per minute
```

JWT Authentication Middleware

```
const jwt = require('jsonwebtoken');

function authenticate(req, res, next) {
  const token = req.headers.authorization?.split(' ')[1];

  if (!token) {
    return res.status(401).json({ error: 'No token provided' });
  }

  try {
    const decoded = jwt.verify(token, process.env.JWT_SECRET);
    req.user = decoded;
    next();
  } catch (err) {
    return res.status(403).json({ error: 'Invalid token' });
  }
}

app.use('/orders', authenticate, createProxyMiddleware({ target: 'http://order-service:3002' }));
```

Request Aggregation

```
app.get('/dashboard', authenticate, async (req, res) => {
  const [user, orders, notifications] = await Promise.all([
    fetch('http://user-service:3001/users/' + req.user.id).then(r => r.json()),
    fetch('http://order-service:3002/orders?user=' + req.user.id).then(r => r.json()),
    fetch('http://notification-service:3004/notifications?user=' + req.user.id).then(r => r.json()),
  ]);

  res.json({ user, orders, notifications });
});
```

Circuit Breaker

```
const CircuitBreaker = require('opossum');

const options = {
  timeout: 3000,
  errorThresholdPercentage: 50,
  resetTimeout: 30000,
};

const breaker = new CircuitBreaker(callService, options);

breaker.fallback(() => ({ message: 'Service unavailable, please try later' }));

app.get('/data', async (req, res) => {
  const result = await breaker.fire();
  res.json(result);
});
```

Best Practices

- **Keep the gateway thin** — don't put business logic in the gateway
- **Use health checks** — the gateway should only route to healthy instances
- **Implement timeouts** — don't wait forever for a slow backend service
- **Log everything** — centralized logging is one of the gateway's biggest benefits
- **Version your APIs** — route `/v1/` and `/v2/` to different service versions
- **Use retries with backoff** — transient failures are common in distributed systems
- **Secure the gateway** — it's the front door, treat it as your most critical component
- **Monitor latency** — the gateway adds a hop, measure the overhead

Common Pitfalls

- **Single point of failure** — always run multiple gateway instances
- **Gateway becomes a bottleneck** — scale horizontally and monitor CPU/memory
- **Too much logic in the gateway** — it should route, not process
- **Tight coupling** — avoid hardcoding service addresses, use service discovery
- **Ignoring latency** — every hop adds milliseconds, keep the gateway lightweight
- **No fallback strategy** — always plan what happens when a service is down

Interview Questions

Q: What is the difference between an API Gateway and a load balancer?

A load balancer distributes traffic across instances of the same service. An API Gateway routes requests to different services, handles auth, rate limiting, and transforms requests. They often work together — the gateway sits behind a load balancer.

Q: How does an API Gateway handle authentication?

The gateway validates the token (JWT, OAuth2) before forwarding the request. It extracts user info from the token and passes it to backend services via headers. Backend services trust the gateway and don't re-authenticate.

Q: What is the BFF pattern?

Backend for Frontend creates separate gateways for different client types. A mobile app may need smaller payloads and different endpoints than a web app. Each BFF is tailored to its client's specific needs.

Q: How do you prevent the API Gateway from becoming a bottleneck?

Run multiple instances behind a load balancer, keep the gateway thin (no business logic), use caching, implement circuit breakers, and monitor performance metrics.

Q: What happens if the API Gateway goes down?

All traffic stops. That's why you run multiple instances with health checks and failover. The gateway is the most critical component in the architecture.

Quick Reference

Concept	Description
Routing	Map URL paths to backend services
Auth	Validate tokens before forwarding
Rate Limiting	Protect services from overload
Aggregation	Combine multiple service responses
Circuit Breaker	Stop requests to failing services
Caching	Store frequent responses
BFF	Separate gateway per client type